Do common password checkers manage to detect sequential patterns, and do they produce false positives in common password detection?

Sneha Patel, Department of Computer Science & Engineering,

SVMIT (affiliated with Gujarat Technological University, GTU),

Gujarat, India

E-mail: sneha.patel.infosec@gmail.com

Abstract

Password strength meters (PSMs) are widely deployed to guide users toward creating secure passwords, yet their effectiveness in detecting real-world weaknesses remains inconsistent. This paper evaluates the ability of common password strength metrics to detect sequential patterns and examines their tendency to produce false positives when assessing human-generated passwords. Using ethically processed subsets of breached passwords alongside randomized and human-designed datasets, we compare Entropy-based scoring, regex-based sequential detection, zxcvbn estimator and the rule-based policy checker. Our results show that although entropy-based and zxcvbn metrics effectively identify low-entropy passwords, they exhibit notable false positive rates when evaluating strong human-generated passwords. In contrast, regex-based sequential detection demonstrates high precision but limited coverage, failing to capture many real-world sequential patterns. Rule-based checkers disproportionately penalize passwords that are contrary to fixed heuristics. These findings highlight systematic biases in current PSMs and emphasize the need for strength estimation methods that better balance usability, pattern awareness, and real-world attack resistance.

Keywords

Password analysis; pattern detection; password heuristics; false positive detection

1. Introduction

"One of the most basic tenets in infosec is the fact that there is no such thing as absolute security." This quote is the first fundamental principle to be covered when introducing any information security concept. While security teams frequently address credential-related risks, password reuse often receives limited attention, as defensive efforts tend to focus on ransomware, phishing, and malware. A TechRepublic survey revealed 53% of people admit to using the same password across multiple accounts. Verizon estimate 86% of attack initial access is gained through stolen credentials. If the same password is used for many devices and applications, only the weakest link needs compromising. [1] According to Cloudflare's monitored traffic, it was identified that 41% of success logins across websites involves compromised passwords. Passwords are recognized to be the first line of defence against unauthorized access of online accounts, devices, and files. But if passwords are so crucial then why do people reuse them? The Reason is straightforward, because it's less effort and less complicated. For any average person that owns more than 10 accounts and create/manage a unique password for each account sounds impractical. [12] Numerous organizations provide password strength meters (PSMs) directly into their services' sign up or login pages. However, the heuristics in PSMs can assist accurately only if their valuation correctly reflects the password strength. As a PSM may backfire if it calculates a low score but a high invulnerability and the other way around. This trait is called a " false positive password " which occurs when a PSM incorrectly flags strong passwords as weak, eventually leading to significant user frustration, increased administrative overheads and false-

-alerts for security teams and unnecessary account locks. Despite multiple password breaches, numerous of these PSMs do not accurately capture password strength and allow users to keep a weak password. The accuracy of password strength checkers varies significantly. Some tools provide realistic assessments based on Entropy calculations and breach database checks, while others use outdated criteria that give high scores to easily crackable passwords, creating dangerous false confidence in weak passwords. [2] Present password checkers typically evaluate based on entropy to estimate the time for brute-force cracking, password length (ideally 12-16+ characters), sequential patterns (i.e. 123, ABC), repeating letters, frequency of uppercase, lowercase, digits and symbols or dictionary pattern matching and keyboard patterns (i.e. qwerty). This Entropy (measured in Shannon (Sh)) is the minimum number of bits necessary to hold the information in a password of a given type, the higher the Entropy score, the higher number of guesses required for an attacker to gain access. [3] Even today, a user's single weak password can cause a train of events for that particular user's other accounts or even to a great extent of breach of the services. Password security is crucial to protect personal data, financial assets, and online identity from cybercriminals and unauthorized access. Strong and unique passwords act as the primary defence against data breaches, identity theft, and credential stuffing preventing attackers from accessing sensitive information like emails, photos, and banking credentials.[12]

RQ : Do common password checkers manage to detect sequential patterns, and do they produce false positives in common password detection?

2. Related Works

In the following, the discussion on password choice, PSM selections & their heuristics, Password checkers and their bias towards certain characteristics of data can be observed. This work makes three contributions:

(1) an empirical comparison of Entropy-based, pattern-based, and rule-based password strength meters using behaviourally distinct datasets.
(2) a quantitative analysis of false positive bias against human-generated passwords.
(3) evidence that commonly deployed sequential pattern detectors exhibit high precision but low recall on real-world breached passwords.

2.1 Entropy-Based Strength Estimation

As previously discussed, Entropy signifies how effective a password is against adversaries who try to guess it or use a brute-force attack. A brute force attack means that someone sets up a script to try all possible combinations of characters to find the password. Such a method eventually would determine your password, provided that the attacker knows the set of characters from which the password consists. Thus, if a password has n bits of Entropy, an attacker needs at most $\mathbf{2^n}$ and on average 2^{n-1} guesses. Entropy of a password can be calculated using:

- Length (in characters)
- Use of numeric characters (0-9)
- Use of uppercase and lowercase letters
- Use of special symbols

Character Type	Example(s)	Range Size
Numeric Characters	0, 1, 2, 3	10
Latin letters (lowercase)	a, b, c, d	26
Latin letters (uppercase)	A, B, C, D	26
Special symbols	!, @, %, $	32

Table 1 : Entropy strength estimation based on character type and its' range size[4]

Here, the broader character range is used, the higher the Entropy score can be achieved and obtains higher security level. [4]

Entropy formula :

$$H = L\ log_2\ N = \ log_2 N^L$$

Where, N is the number of possible symbols and L is the number of symbols in the password. H is measured in bits. [5]

Short or predictable passwords are quickly broken by automated tools. By contrast, longer passwords with diverse character sets generate exponentially higher entropy, making them resilient even against powerful GPUs or distributed cracking clusters. [15]

For instance, a password being 'ashelybrown' contains only lowercase letters, resulting into a low Entropy score while a password being 'ashBR!01' will contain a significantly higher Entropy score. The 60-bit threshold is adopted as a comparative baseline consistent with prior password strength studies, rather than as an absolute security guarantee.

2.2 Regex-Based Sequential Pattern Detection

"Regex" refers to "Regular Expression" and it seeks to match specific patterns in a string. A basic regex checker checks for alphanumeric characters and metacharacters. For this analysis, we have used only alphanumeric character-based checker that checks for alphanumeric and keyboard patterns. [6]

The implemented regex pattern detector identifies strictly consecutive ASCII sequences of length ≥4.

2.3 Rule-based (Policy-Based) Checker

A common password checker is the project majority of all cybersecurity professionals have built once in their undergraduate careers. A basic password checker examines the password's length (typically minimum length being >=8), and contains alphanumerical letters and at-least one special character. Irrespective of the strength based solely on the basic password checker, combining it with other powerful algorithms (for sequence check, repetition check, previous-breach check, dictionary word check) can produce a robust password checker.

2.4 Zxcvbn Score Checker

Zxcvbn is an open-source, JavaScript-based password strength estimator developed by Dropbox. This checker evaluates password security based on Entropy and pattern matching, rather than arbitrary complexity rules that are contained in basic password checker. A zxcvbn score is calculated based on:

- Sequences
- Dictionary words
- Keyboard patterns
- Human-chosen passwords

Zxcvbn provides a score from 0 to 4:

Score	Strength	Meaning
0	Very Weak	Guessable in less than 10^3 attempts
1	Weak	Guessable in less than 10^6 attempts
2	Fair	Guessable in less than 10^8 attempts
3	Strong	Guessable in less than 10^{10} attempts
4	Very Strong	Requires significant computational resources

Table 2 : Zxcvbn score grading

Moreover, it estimates actual cracking time based on different attack scenarios and provides detailed feedback for improvement. [7] [8]

3. Methodology

All password datasets were processed in batch mode using an automated evaluation pipeline. Only aggregate statistics were retained; no individual passwords or per-password outputs were stored or published.

3.1 Evaluated Datasets

For this analysis, a small, non-redistributed subset of the RockYou dataset was used strictly for academic password-strength analysis. The dataset was processed locally and never applied to real user accounts. A randomly sampled 10,000-entry subset of the RockYou dataset was processed in an isolated virtual machine environment to ensure system safety and ethical handling of sensitive data. Passwords were then categorized into behavioural classes using transparent rule-based heuristics, including sequential patterns, frequency dominance, and character-set range. A synthetic random baseline was generated for controlled comparison.

Created dataset names	Dataset Size
Common_subset	948
Random_baseline	1000
sequential	565
Strong_human	254

Table 3 Datasets and dataset sizes

3.2 Password Metrics Evaluation

To calculate Entropy, the score is initially set at 0 and the effective character set size N was inferred from the distinct character classes present in the password, and Entropy was computed as $H = L \times \log_2(N)$.

To estimate regex pattern detection rate, each password was compared through the implemented sequential detector that identifies strictly consecutive ASCII sequences of length ≥4. The conclusion is then returned in terms of simple True or False. 'True' was returned as the sequential pattern discovered rate.

The zxcvbn score is evaluated on a scale of 0 to 4 based on the estimated time it would take to crack the password where 4 is considered a "strong" password. Contrarily to usual password heuristics, zxcvbn focuses highly on length of the password than the complexity of the password. For this analysis, passwords having zxcvbn score of ≤ 2 were flagged as "weak".

In this study, false positives are defined as *disagreement-based false positives*, where a password exhibits high estimated Entropy (≥ 60 bits) but is nevertheless classified as weak by at least one heuristic-based strength meter (regex-based detection or zxcvbn score ≤ 2). This definition isolates heuristic bias rather than absolute password weakness and enables comparison between human-generated and randomly generated passwords under an offline attack model. [9]

False positives pose a significant challenge not only for PSMs but for security practitioners on a broader scale. In this analysis, False positives were measured using the strong-human and random-baseline datasets against the available Password Strength Meters. The results were biased to some extent based on PSM and type of dataset used.

4. Results

This analysis assumes an offline attacker model in which adversaries may perform high-speed guessing using breached password datasets. Online rate-limited attacks are out of scope.

To ensure the ethical handling of the sensitive data, the datasets of subset of the RockYou list were processed in an isolated virtual machine environment. We measured behaviour of the present Entropy score checker, Regex pattern detector, zxcvbn checker and standard checker against each of the primary datasets. Each password was evaluated by each PSM's heuristics of a "weak" password.

Here,

1. Each Password categorized by dataset (Common subset, Random baseline, Sequential, Strong human)
2. Entropy score (%) was calculated by (passwords with Entropy<60 * 100) / total passwords of the dataset
3. Regex rate (%) was estimated using (total passwords flagged as weak * 100) / total passwords of the dataset [Here, a password is considered weak if it matches a predefined sequential pattern and is flagged by the detector.]
4. Zxcvbn rate (%) was calculated using (passwords having zxcvbn score <=2 *100)/ total passwords of the dataset
5. Policy-based acceptance rate was computed by number of passwords accepted as strong by policy checker * 100 / total passwords of the dataset
6. Disagreement-based false positive rate was estimated using count of passwords where: Entropy ≥ 60 AND (regex = weak OR zxcvbn ≤ 2))* 100 / total passwords

Password type (datasets used)	Entropy score <60 (%)	Regex-based pattern match rate (%)	Zxcvbn score <=2 (%)	Standard policy-based strength acceptance rate (%)	Detection disagreement rate (%)
Common_subset	81.85%	0.105%	74.26%	0.210%	4.43%
Random_baseline	0%	0%	0%	65.6%	0%
Sequential	78.76%	10.97%	67.07%	1.061%	5.48%
Strong_human	18.50%	0%	21.65%	5.905%	14.96%

Table 4 Results table

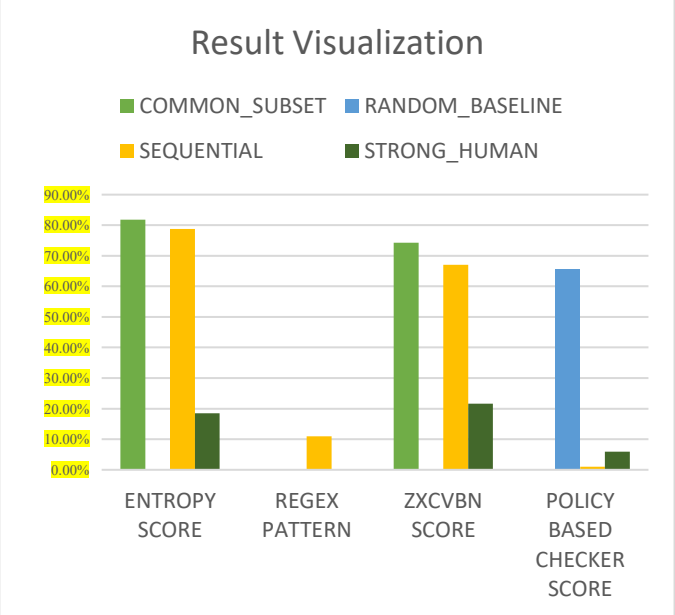


Figure 1 Data visualization where x axis contains each PSM used, y axis contains the rate of detection

Checker type	Detection rate(%)		Bias
	Random_baseline dataset	Strong_human dataset	
Entropy-checker	0%	18.50%	Human-biased
Regex sequence	0%	0%	Unbiased
zxcvbn	0%	21.65%	Human-biased
Basic checker	34.4%	5.905%	Rule-biased

Table 5 Detector bias relative to entropy-based acceptance rate

Bias here refers to differential rejection behaviour across datasets under entropy-conditioned acceptance and does not imply ground-truth error.

5. Analysis & Discussion

The results table indicates that random character dataset has 0% flag rate as 'weak' in Entropy, regex and zxcvbn strength meters. However, it flags them due to missing a digit or having less length. In addition to the regex-based sequential detector identified only ~11% of passwords from the sequential dataset, highlighting a significant gap between theoretical sequential definitions and real-world password patterns.

Now for our research question,

RQ : Do common password checkers manage to detect sequential patterns, and do they produce false positives in common password detection?

While the rule-based checker rejected the majority of strong-human passwords, most rejections were policy-driven rather than Entropy–heuristic disagreement-based false positives. This highlights the limitations of composition-based policies in accurately assessing real-world password strength.

Whereas, Entropy-based and zxcvbn checker exhibited higher detection disagreement rates on human-generated strong passwords, while rule-based systems disproportionately penalized randomly generated passwords. Regex-based sequential detection demonstrated high precision but limited coverage, indicating low recall.

Table 5 reports the percentage of passwords accepted by the entropy-based checker (entropy ≥ 60) but rejected by other strength estimators. Rather than representing classification error, these values quantify systematic disagreement and highlight detector-specific bias toward or against human-generated passwords.

6. Limitations

For this analysis, the implemented sequential detector identifies strictly consecutive ASCII sequences of length ≥4.

As a result, non-linear or keyboard-based sequences are not detected, leading to lower recall on the sequential dataset.
The checkers tend to be marginally biased towards human-based patterns as a consequence of the detection rate being higher for strong human passwords. Hence numerous password strength meters flag human-made passwords incorrectly. [9]

7. Conclusion

We have concluded our first small-scale analysis on password strength meters and their behaviour towards various datasets finding that no password is absolutely invulnerable and that its perceived strength varies across different password strength meters. Though the passwords separated into datasets based on their characteristics, only a compact portion of breached sequential passwords were flagged as weak for containing a weak pattern.

According to the data, simple heuristics in PSMs enforce password length, use of uppercase/lowercase letters, digits and special characters but it fails to detect common patterns, substitutions, reuse and predictability, as a reason of this number of password checkers pass weak passwords as strong and fail strong-but-unusual passwords. Due to this, policy-only password rules may act inefficient to password-security. Machine-generated passwords demonstrate lower detection disagreement rates under current PSM heuristics, highlighting a misalignment between human memorability and automated strength evaluation.

For added security, use of password managers like 1Password, KeePass, and Bitwarden serves well as it needs to create one strong master password, and the password manager generates unique, random passwords for every site and stores them encrypted. Furthermore, periodically staying updated with password breaches (like Have I Been Pwned) and evaluation of your passwords with breached passwords may aid in staying up-to-date for password security. [10] [11]

8. References

[1] Specopssoft. 2025. Password reuse: A hidden danger you can't ignore
Retrieved January 2026 from: https://specopssoft.com/blog/password-reuse-hidden-danger/

[2] GenSGPT. 2024. Password Strength Checkers: How Accurate Are They?
Retrieved January 2026 from: https://www.gensgpt.com/blog/password-strength-checkers-how-accurate

[3] Wikipedia. 2006. Password strength
Retrieved January 2026 from: https://en.wikipedia.org/wiki/Password_strength#

[4] Proton.me. 2023. What is password entropy?
Retrieved January 2026 from: https://proton.me/blog/what-is-password-Entropy

[5] Bill Burr, Tim Polk and Donna Dodson. National Institute of Standards and Technology (NIST), NIST Special Publication 800-63 Version 1.0, 53 pages, 2004.

[6] Formulas HQ Blog, The Ultimate Guide to Regex for Password Validation.
Retrieved January 2026 from: https://formulashq.com/the-ultimate-guide-to-regex-for-password-validation/

[7] Dev.to. 2024. Password Strength Testing with zxcvbn: A Deep Dive into Modern Password Security
Retrieved February 2026 from: https://dev.to/tooleroid/password-strength-testing-with-zxcvbn-a-deep-dive-into-modern-password-security-2hl8

[8] Dropbox. 2012. zxcvbn: Realistic Password Strength Estimation.
GitHub repository: https://github.com/dropbox/zxcvbn

[9] David Temoshok, Diana Proud-Madruga, Yee-Yin Choong, Ryan Galluzzo, Sarbari Gupta, Connie LaSalle, Naomi Lefkovitz, Andrew Regenscheid. NIST Special Publication NIST SP 800-63-4, 2025. Digital Identity Guidelines

[10] Dropbox.tech. 2012. zxcvbn: realistic password strength estimation
Retrieved January 2026 from: https://dropbox.tech/security/zxcvbn-realistic-password-strength-estimation#:~:text=zxcvbn%20is%20a%20password%20strength%20meter%20that,as%20the%20sum%20of%20its%20constituent%20patterns

[11] Ur, Blase, et al. "How does your password measure up? The effect of strength meters on password creation." *21st USENIX security symposium (USENIX Security 12)*. 2012.

[12] LinkedIn. 2026. Why Password Reuse Is Dangerous (And How to Stop It)
Retrieved February 2026 from: https://www.linkedin.com/pulse/why-password-reuse-dangerous-how-stop-laone-moalosi-nmbzf/

[13] Pereira, David, Joao F. Ferreira, and Alexandra Mendes. "Evaluating the accuracy of password strength meters using off-the-shelf guessing attacks." *2020 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW)*. IEEE, 2020.

[14] Wang, Ding, et al. "No single silver bullet: Measuring the accuracy of password strength meters." *32nd USENIX Security Symposium (USENIX Security 23)*. 2023.

[15] Password-tools.com. 2026. Password Entropy Calculator
Retrieved February 2026 from: https://password-tools.com/utils/password-entropy-calculator/